

LEARNING RESOURCE GUIDE

ISC2 CCSP: Certified Cloud Security Professional (Aug 2026) | Professional Participant Workbook

Learning Objectives

By the end of this lecture and its accompanying guide, you will be able to:

- By the end of this lecture, you will be able to map ISO 27001, ISO 27017, and ISO 27018 to their distinct roles in cloud security assurance.
- By the end of this lecture, you will be able to explain the three assurance levels of the CSA STAR program and interpret a CAIQ/CCM-based assessment.
- By the end of this lecture, you will be able to identify when PCI DSS applies to a cloud deployment and interpret a CSP Responsibility Matrix.
- By the end of this lecture, you will be able to evaluate contractual provisions — audit rights, data residency, incident notification, and data return — as part of a structured CSP due diligence process.
- By the end of this lecture, you will be able to construct a practical CSP evaluation framework that synthesises certification evidence, audit reports, and contractual terms.

Introduction

Selecting a cloud service provider is one of the most consequential security decisions an organisation makes. Once workloads, data, and processes are running on a provider's infrastructure, reversing that decision is expensive and disruptive. The due diligence performed before signing a contract is the primary control. Part 2 of this CSP evaluation series focuses on the documentary and contractual evidence a security professional must gather and interpret: third-party certifications, assurance frameworks, and the contract clauses that define the residual obligations each party accepts.

Third-party certifications transform a CSP's self-reported security posture into independently verified assurance. ISO 27001 certifies that a formal Information Security Management System exists and has been assessed against an internationally recognised standard. CSA STAR extends that assurance with cloud-specific controls drawn from the Cloud Controls Matrix. SOC 2 Type II — covered in Part 1 — demonstrates sustained control effectiveness over time. PCI DSS applies when cardholder data is in scope. Each framework answers a slightly different question, and a rigorous evaluation triangulates across all relevant certifications rather than accepting any single one in isolation.

Contractual due diligence is equally important and frequently underweighted. Certifications describe the CSP's general security programme; contracts define the specific obligations that apply to your engagement. Audit rights, data residency constraints, breach notification timelines, and data return and deletion procedures are not implied by a certification — they must be explicitly negotiated and documented. A CSP with an impeccable certification portfolio but a contract that waives audit rights or provides no data residency guarantees may not meet the regulatory and risk management requirements of your organisation.

Core Concepts Explained

ISO 27001 and Its Cloud Extensions (27017 and 27018)

Definition: ISO 27001 is the international specification for an Information Security Management System (ISMS), requiring systematic risk assessment and a defined set of security controls. ISO 27017 adds cloud-specific controls covering shared-responsibility boundaries, administrative access to cloud-hosted systems, and virtual machine configuration. ISO 27018 adds privacy controls for personally identifiable information processed in cloud environments, addressing consent, transparency, data portability, and retention limits.

Business relevance: For organisations operating under GDPR, sector privacy regulations, or cross-border data protection regimes, ISO 27017 and 27018 certifications provide structured evidence that the CSP manages cloud-specific security and privacy risks within an independently audited framework — reducing the effort required for your own compliance gap analysis.

Cloud Security Practitioner relevance: As a Cloud Security Practitioner, you use ISO 27001 certification to confirm that a CSP operates a systematic, auditable security programme. You use 27017 to verify that cloud-specific shared-responsibility boundaries are formally defined, and 27018 to confirm that the CSP meets privacy obligations relevant to GDPR and similar regulations — particularly when the CSP processes personal data on your behalf as a data processor.

Real-world example: A European FinTech firm shortlisting two IaaS providers issues a due diligence questionnaire that includes: 'Provide your current ISO 27001 certificate, the issuing certification body name, and the date of your last recertification audit.' Provider A supplies an ISO 27001 certificate issued by BSI Group (an UKAS-accredited body), with a recertification date six months prior and surveillance audit completion documented. Provider B supplies a certificate issued by a lesser-known body with no UKAS or DAkkS accreditation, and the certificate expired eight months ago. The practitioner verifies both certifications through the issuing bodies' public registries. Provider B is immediately flagged for remediation: the expired certificate means independent assurance has lapsed, and the non-accredited issuing body means the original assessment may not have met ISO 17021 conformity assessment requirements. The firm requires Provider B to demonstrate current certification before the shortlist advances — a best practice that prevents accepting stale or low-quality assurance.

Risks or limitations: An ISO 27001 certificate is only as current as its last surveillance audit. Certificates are renewed every three years with interim surveillance audits. A certificate that is six months from its three-year anniversary without a documented surveillance audit may indicate the provider is not maintaining their ISMS. Always verify certification currency through the issuing body's public registry rather than relying solely on the certificate document provided by the CSP.

CSA STAR Program and the Cloud Controls Matrix

Definition: The Cloud Security Alliance Security, Trust, Assurance and Risk (STAR) program provides cloud-specific assurance at three levels: Level 1 is self-assessment via the Consensus Assessments Initiative Questionnaire (CAIQ) mapped to the Cloud Controls Matrix (CCM); Level 2 is third-party assessment against the CCM, typically combined with ISO 27001; Level 3 (STAR Continuous) involves automated continuous monitoring. The Cloud Controls Matrix (CCM) is the underlying control framework, covering domains including data security, infrastructure security, IAM, and audit assurance, with mappings to ISO 27001, NIST SP 800-53, PCI DSS, and HIPAA.

Business relevance: The CSA STAR registry is publicly searchable, providing an immediately accessible baseline for any CSP under evaluation. A CAIQ available in the registry enables a security team to perform control-gap analysis against the CCM without requiring the CSP to respond to a custom questionnaire, significantly

accelerating due diligence. STAR Certification at Level 2 adds independent verification, increasing confidence in the self-assessed claims.

Cloud Security Practitioner relevance: As a Cloud Security Practitioner, you use the CAIQ to perform a rapid gap analysis against the CCM domains most relevant to your deployment. The CCM's cross-reference to other frameworks enables efficient multi-framework compliance mapping: if you need evidence of a control required by both NIST SP 800-53 and PCI DSS, a single CCM control entry can point you to the CSP's evidence for both. For organisations under multiple regulatory regimes, this cross-mapping capability reduces duplicated assessment effort substantially.

Real-world example: A healthcare technology company evaluating three CSPs for a workload containing Protected Health Information (PHI) uses the CSA STAR registry as the first filter. Provider A has a STAR Level 2 certification combined with ISO 27001, with the CAIQ and assessment report publicly available. Provider B has a Level 1 self-assessment only, published eighteen months ago. Provider C has no STAR entry. Using the CCM, the practitioner maps the IAM and data security control domains to the HIPAA Security Rule requirements they need to demonstrate. For Provider A, most CCM control responses are independently verified and map directly to the required HIPAA controls. For Provider B, the practitioner notes that the self-assessment is unverified and nearly two years old — the data security controls in the CCM may have changed, and the accuracy of the responses cannot be confirmed. Provider C requires a full custom questionnaire process. The practitioner recommends Provider A for shortlisting and requires Provider B to provide a current CAIQ and supplemental evidence before advancing. This structured approach — STAR registry first, custom questionnaire second — is the industry best practice for efficient CSP evaluation.

Risks or limitations: A CAIQ at STAR Level 1 is self-attested with no independent verification. A CSP can publish optimistic or inaccurate responses without external challenge. When using a CAIQ for due diligence, treat Level 1 responses as a starting point for targeted verification questions rather than as confirmed evidence. Where the control in question is high-risk or directly tied to regulatory compliance, require Level 2 certification or supplemental third-party evidence.

PCI DSS in Cloud Environments and the Responsibility Matrix

Definition: The Payment Card Industry Data Security Standard (PCI DSS) applies to any system that processes, stores, or transmits payment card data. In cloud environments, the CSP is responsible for PCI DSS compliance for the portions of the infrastructure they control under the shared responsibility model. CSPs that provide infrastructure for cardholder data environments typically publish a PCI DSS Responsibility Matrix — a document that maps each PCI DSS requirement to the party responsible for meeting it: the CSP, the customer, or a shared responsibility.

Business relevance: PCI DSS compliance failures carry significant financial and reputational consequences, including fines from card brands, mandatory forensic investigations, and potential loss of payment processing rights. When a cloud environment is in scope for PCI DSS, the shared responsibility model creates compliance gaps if either party misunderstands which requirements they own. The Responsibility Matrix eliminates ambiguity, but only if both parties read, understand, and agree to it before deploying cardholder data environments.

Cloud Security Practitioner relevance: As a Cloud Security Practitioner, you must obtain and review the CSP's PCI DSS Responsibility Matrix before placing any cardholder data workload in their environment. Requirements the matrix assigns to the customer — such as application-layer access control, encryption key management, or security log retention — must be implemented by your organisation, not assumed to be covered by the CSP's own PCI DSS attestation. Gap analysis against the Responsibility Matrix is the mechanism by which you scope your own compliance obligations within a cloud deployment.

Real-world example: A retail chain migrating its e-commerce payment processing to an IaaS provider obtains the provider's PCI DSS Responsibility Matrix. The matrix shows that the CSP fulfils PCI DSS requirements 9 (physical access) and 11.1 (external vulnerability scanning for the physical infrastructure layer) but assigns to the customer the responsibility for requirements 6 (secure development of payment applications), 7 (access restriction based on business need), and 10 (audit log generation and retention for cardholder data environment systems). The practitioner builds a compliance implementation plan that maps each customer-owned requirement to a specific technical control: application vulnerability scanning tools for Requirement 6, role-based access control policies for Requirement 7, and a dedicated SIEM with 12-month log retention for Requirement 10. During the annual QSA assessment, the practitioner can present this mapping as evidence that customer responsibilities were formally identified and addressed before go-live — the best practice approach that prevents compliance gaps from emerging only during audit.

Risks or limitations: A common mistake is assuming that a CSP's PCI DSS Attestation of Compliance (AoC) covers the entire cardholder data environment, including customer-managed systems. The AoC covers only the CSP's scope. Customer applications, operating systems, and workloads running on top of the CSP's infrastructure are the customer's PCI DSS responsibility unless explicitly stated otherwise. Always read the Responsibility Matrix in conjunction with the AoC.

Contractual Provisions: Audit Rights, Data Residency, Incident Notification, and Data Return

Definition: Beyond certifications, CSP contracts must address four critical security provisions: (1) Audit rights — the right to audit or designate a third party to audit the CSP's controls; (2) Data residency — geographic constraints on where data is stored, relevant to GDPR, data sovereignty, and sector regulations; (3) Incident notification — contractual timelines and information requirements for breach notification, relevant to GDPR's 72-hour notification requirement; (4) Data return and deletion — procedures for returning data and verifying destruction upon contract termination.

Business relevance: Regulatory bodies do not accept a CSP contract's silence on these provisions as an excuse for non-compliance. If GDPR requires notification to the supervisory authority within 72 hours of breach discovery and the contract does not obligate the CSP to notify you within a shorter timeframe, you have a compliance gap — one that may result in a fine even though the breach occurred on the CSP's infrastructure. These contractual provisions are the legal mechanism by which you translate regulatory obligations into enforceable CSP commitments.

Cloud Security Practitioner relevance: As a Cloud Security Practitioner, you review contract language for these four provisions before legal finalisation and flag any gaps to your legal and compliance team. When a large CSP declines to grant direct audit rights (a common position), you evaluate whether their SOC 2 Type II report frequency, CCM assessment recency, and ISO 27001 surveillance audit schedule collectively provide sufficient assurance as a substitute. This is a risk-based judgement — acceptable for lower-risk workloads, but potentially unacceptable for highly regulated data.

Real-world example: A financial services firm negotiating a multi-year IaaS contract finds that the CSP's standard contract includes a 30-day incident notification clause — the CSP commits to notifying the customer within 30 days of confirming a breach. Under GDPR Article 33, the firm must notify its supervisory authority within 72 hours of becoming aware of the breach. If the CSP takes 30 days to notify, the firm has already missed the regulatory deadline and faces potential enforcement action. The practitioner escalates this gap to the legal team, and the contract is renegotiated to include a 24-hour notification commitment for any security event that may involve personal data — a best practice that aligns the CSP's contractual obligation with the firm's regulatory deadline, providing a buffer for the firm's own internal triage and notification process. The firm also negotiates a data residency clause restricting all data to EU-based data centres with documented controls preventing cross-border replication without written consent.

Risks or limitations: Data deletion provisions are frequently overlooked. When a contract ends, data backups, replicated copies, and cached data may persist on CSP infrastructure beyond the primary deletion. Without a contractually specified deletion procedure that includes confirmation of backup and replica destruction, your organisation may not be able to demonstrate that all copies of regulated data have been destroyed — an audit finding under GDPR's right to erasure and data minimisation requirements.

Practical CSP Evaluation Framework

Definition: A structured CSP evaluation framework combines multiple evidence sources in a defined sequence: publicly available security documentation and compliance pages; SOC 2 Type II reports (requested under NDA if not public); ISO 27001 certification verification through the issuing body; FIPS 140-2/140-3 validation status on the NIST CMVP website; CSA STAR registry review; incident history and communications track record; and contract review with legal and compliance support.

Business relevance: A documented evaluation framework creates an auditable record demonstrating that security due diligence was performed before onboarding a CSP. This documentation is valuable during regulatory audits, security assessments, and incident investigations, where demonstrating that vendor risk management processes were followed is as important as the technical controls implemented.

Cloud Security Practitioner relevance: As a Cloud Security Practitioner, you own the security due diligence portion of the CSP evaluation. By following a structured framework, you ensure no evidence category is omitted, produce consistent outputs that can be compared across providers, and create documentation that supports both the procurement decision and future audit inquiries.

Real-world example: An enterprise cloud security team is evaluating two CSPs for a workload that will process regulated financial data. They create a CSP Evaluation Report using the structured framework. Step one: both CSPs' compliance documentation pages are reviewed. CSP A lists SOC 2 Type II, ISO 27001, ISO 27017, PCI DSS Level 1, FedRAMP Moderate, and CSA STAR Level 2. CSP B lists ISO 27001 and SOC 2 Type I (not Type II). The practitioner immediately flags that SOC 2 Type I only confirms controls existed at a point in time, not that they operated effectively over a period — a significant assurance gap. Step two: ISO 27001 certificates for both are verified through BSI Group's public registry. CSP A's certificate is current; CSP B's was issued by a non-accredited body. Step three: the CSA STAR registry shows CSP A with a current STAR Level 2 combined assessment; CSP B has a self-assessment over two years old. Step four: the contract review reveals CSP B's standard agreement has a 30-day breach notification clause, no data residency commitment, and no explicit data deletion procedure. The practitioner recommends CSP A based on superior multi-layered assurance and uses the documented evaluation report to support the recommendation to the risk committee.

Risks or limitations: The primary risk in CSP evaluation is treating any single certification as comprehensive assurance. ISO 27001 does not address cloud-specific controls; SOC 2 Type II does not cover cardholder data; PCI DSS does not address privacy. A rigorous evaluation uses frameworks appropriate to the data types and regulatory requirements specific to the workload — and documents the mapping between evaluation evidence and those specific requirements.

Practical Applications

The following scenarios illustrate how Cloud Security Practitioners apply certification analysis and contractual due diligence in real organisational settings.

Performing Due Diligence Before Migrating Regulated Data to the Cloud

A practitioner at a pharmaceutical company is leading the migration of clinical trial data to a cloud-hosted research platform. The data is subject to HIPAA, GDPR (the organisation operates in Germany), and FDA 21 CFR Part 11 electronic records requirements. The practitioner begins with the CSA STAR registry and downloads the CAIQ for the shortlisted provider, cross-referencing CCM control domains for data security, cryptography, and IAM. The CCM mappings to ISO 27001 and NIST SP 800-53 are used to confirm alignment with the FDA's guidance on computer systems validation. The practitioner then requests the SOC 2 Type II report under NDA, verifying that the audit period covered the previous 12 months and that the auditor's opinion is clean with no significant exceptions. ISO 27001, 27017, and 27018 certificates are verified through the issuing body's registry — a best practice that prevents accepting forged or expired certificates. Contract review focuses on data residency (EU data centres only), a 24-hour breach notification clause to meet GDPR Article 33 requirements, and a detailed data deletion procedure specifying destruction of all backup copies within 30 days of contract termination. This layered approach — registry, audit report, certification verification, contract — is the gold standard for regulated data migrations.

Responding to an Auditor's Request for CSP Security Evidence

During an annual ISO 27001 surveillance audit of an organisation's own ISMS, the auditor asks for evidence that cloud service providers used by the organisation have been assessed for security risk. The practitioner retrieves the CSP Evaluation Reports completed at the time of onboarding for each major provider, showing the evidence collected from the structured evaluation framework: certification status at onboarding, SOC 2 Type II report copies, CAIQ downloads from the STAR registry, and the contract provisions review checklist. The auditor asks specifically about the most recent evidence — whether CSP certifications are still current. The practitioner demonstrates that the organisation's vendor risk management process includes an annual review of CSP certification status, with the most recent review documented in the organisation's vendor risk register. For the two CSPs where ISO 27001 certificates are within six months of their three-year renewal date, the practitioner has already sent renewal confirmation requests to the providers. This demonstrates ongoing due diligence rather than a one-time assessment — a best practice that satisfies both the ISO 27001 auditor and any regulatory examination of third-party risk management.

Handling a Contract Negotiation for a High-Risk Workload

A practitioner is supporting the procurement team in negotiating a contract for a CSP that will host a workload processing both payment card data and personal health information. The standard contract presented by the CSP includes a 30-day incident notification clause, no data residency guarantee, and a vague data deletion clause that says 'data will be deleted within a reasonable time after contract termination.' The practitioner documents three specific gaps against regulatory requirements: the 30-day notification exceeds both GDPR's 72-hour and PCI DSS's 'prompt' notification requirements; the absence of data residency guarantees may violate GDPR's data transfer restrictions; and the vague deletion language does not satisfy GDPR's right to erasure documentation requirements. The practitioner prepares a formal Security Requirements Addendum specifying: notification within 24 hours of identifying any security event potentially involving customer data; data restricted to EU-based data centres with a documented list of facilities; and deletion of all copies — including backups, replicas, and snapshots — within 30 days of termination, with written confirmation from the CSP. The practitioner presents the addendum to the procurement team alongside the regulatory citations for each requirement, enabling an informed negotiation where security requirements are grounded in specific obligations rather than general preferences.

Best Practices

- **Verify certifications through the issuing body's public registry, not only the certificate document.** Certificate documents can be forged, altered, or left in circulation after expiry. BSI Group, DNV, Bureau Veritas, and other accredited certification bodies maintain online registries where you can confirm that a specific organisation holds a current ISO 27001 certificate by searching the organisation name and certificate number. Build this verification into your CSP evaluation checklist as a mandatory step with documented evidence of the registry check.
- **Treat SOC 2 Type II as the minimum acceptable audit standard for cloud security assurance — reject Type I for ongoing evidence.** SOC 2 Type I only confirms that controls were designed and in place at a specific date. It does not confirm they operated effectively. A CSP who offers only a Type I report cannot demonstrate sustained operational effectiveness. For cloud workloads carrying sensitive or regulated data, require a Type II report covering at least the previous 6 to 12 months, and verify that the auditor's opinion contains no significant exceptions related to controls relevant to your data.
- **Negotiate incident notification clauses to a timeline shorter than your regulatory obligations, creating response buffer.** If GDPR requires you to notify within 72 hours, a CSP notification clause of 30 days creates a gap where you may miss your regulatory deadline through no operational fault of your own. Best practice is to negotiate the CSP's notification to 24 hours for any security event potentially involving personal data, giving your organisation time to triage, assess severity, and prepare the supervisory authority notification within the 72-hour window.
- **Use the CCM as a cross-reference tool for multi-framework compliance mapping rather than performing separate assessments per framework.** The Cloud Controls Matrix maps its control domains to ISO 27001, NIST SP 800-53, PCI DSS, HIPAA, and other frameworks. When you assess a CSP against CCM, you simultaneously gather evidence applicable to multiple regulatory frameworks. Document which CCM controls satisfy which regulatory requirements in a compliance mapping spreadsheet, reducing the effort of re-assessing the same CSP evidence for each framework independently.
- **Document data deletion requirements and verification procedures before contract signing, not after workload termination.** Data deletion obligations under GDPR and sector regulations require proof of destruction — not merely a CSP's verbal assurance. Before signing, specify in the contract the timeline for deletion (e.g. 30 days post-termination), the scope (primary data, all backups, replicas, and cached copies), and the form of confirmation (a written certificate of destruction specifying the deletion method used). Without these provisions in the contract, you have no enforceable basis for requesting this evidence at termination.

Common Mistakes and Misconceptions

Misconception: Accepting a CSP's word that they are 'ISO 27001 certified' without verifying the certificate currency and the accreditation status of the issuing body.

Correct approach: Always verify ISO 27001 certification through the accredited certification body's public registry. Confirm the certificate is current (within the three-year certification cycle with documented surveillance audits), and confirm the issuing body is accredited by a recognised national accreditation body (UKAS, DAKKS, ANAB, etc.).

Misconception: Treating a CSA STAR Level 1 CAIQ as equivalent to independently verified assurance.

Correct approach: STAR Level 1 is self-attested. Use it as a structured starting point for targeted verification questions, and require STAR Level 2 certification or supplemental third-party evidence for high-risk controls.

Misconception: Assuming that a CSP's PCI DSS Attestation of Compliance covers all customer systems running on top of their infrastructure.

Correct approach: The CSP's AoC covers only the CSP's infrastructure scope. Obtain and review the PCI DSS Responsibility Matrix to identify which PCI DSS requirements are the customer's obligation, and build those controls into your own compliance programme before placing cardholder data workloads.

Misconception: Completing security due diligence only at the time of CSP onboarding and not repeating it annually.

Correct approach: CSP certifications expire, audit reports become stale, and the CSP's security programme may change. Implement an annual vendor risk review that re-verifies certification currency, requests the most recent SOC 2 Type II report, and checks for any changes to the contractual provisions or the Responsibility Matrix.

checklist: CSP Evaluation Due Diligence Checklist

Use this checklist for each CSP being evaluated for workloads carrying sensitive or regulated data. Document the evidence source for each item to create an auditable due diligence record.

- ☐ Step 1 — Public documentation review: Download the CSP's security whitepaper, compliance documentation page, and any publicly available audit reports.
- ☐ Step 2 — SOC 2 Type II: Request the most recent SOC 2 Type II report under NDA. Confirm audit period covers at least 6 months. Review auditor opinion for exceptions.
- ☐ Step 3 — ISO 27001 verification: Obtain the certificate. Verify currency and accreditation status through the issuing body's public registry. Confirm surveillance audit history.
- ☐ Step 4 — ISO 27017 / 27018 (if applicable): Verify cloud-specific and privacy-specific certifications through the same registry process.
- ☐ Step 5 — CSA STAR registry: Search the public registry. Note the assurance level (1, 2, or 3). Download the CAIQ. Check the publication date — reject CAIQs older than 18 months as primary evidence.
- ☐ Step 6 — CCM gap analysis: Map CCM control domains to your specific regulatory requirements (GDPR, HIPAA, PCI DSS, NIST SP 800-53). Identify gaps requiring supplemental evidence.
- ☐ Step 7 — PCI DSS (if in scope): Obtain the Responsibility Matrix. Map each customer-owned requirement to a planned technical control in your environment.
- ☐ Step 8 — FIPS 140-2/140-3 (if required): Verify cryptographic module validation status on the NIST CMVP website.
- ☐ Step 9 — FedRAMP (US government workloads): Verify authorization status and impact level on the FedRAMP Marketplace.
- ☐ Step 10 — Incident notification history: Research publicly known incidents involving the CSP. Assess the timeliness and quality of their communications.
- ☐ Step 11 — Contract review: Audit rights (direct or third-party), data residency (specific regions/facilities), incident notification timeline (24 hours for personal data), data return format, and deletion procedure with confirmation.

- ☐ Step 12 — Document and retain: Save all evidence with retrieval date, source URL or NDA reference, and evaluator name. Store in the organisation's vendor risk register.

How to use this: *This checklist should be completed before workload deployment and reviewed annually. For high-risk workloads, engage your legal and compliance team for contract review and your internal audit team to validate the completeness of evidence collected.*

Knowledge Check

Test your understanding before moving on. Answers are shown below each question.

Q1. A CCSP candidate is evaluating a CSP that presents an ISO 27001 certificate issued 28 months ago by a certification body the candidate cannot find in any national accreditation registry. Which action best addresses this situation?

- A) A. Accept the certificate because 28 months is within the three-year certification cycle.
- B) B. Request the CSP's most recent surveillance audit report and verify the issuing body's accreditation status through a national accreditation authority.
- C) C. Require the CSP to obtain a new ISO 27001 certificate immediately before proceeding.
- D) D. Accept the certificate and rely on the CSP's SOC 2 Type II report as additional assurance.

Answer: B. Request the CSP's most recent surveillance audit report and verify the issuing body's accreditation status through a national accreditation authority.

Q2. An organisation is preparing to deploy a workload that processes EU citizens' personal health data on a US-based IaaS provider. The provider's standard contract includes a 30-day incident notification clause and no data residency restrictions. Which contractual provisions must the practitioner negotiate before deployment?

- A) A. A shorter incident notification timeline aligned with GDPR Article 33 and explicit data residency restrictions for EU data.
- B) B. Only a shorter incident notification timeline, as data residency is a technical rather than contractual control.
- C) C. Only data residency restrictions, as GDPR's notification requirement applies to the organisation rather than the CSP.
- D) D. Neither provision requires negotiation; the CSP's ISO 27001 certification covers GDPR compliance.

Answer: A. A shorter incident notification timeline aligned with GDPR Article 33 and explicit data residency restrictions for EU data.

Q3. A CSP presents a CSA STAR Level 1 CAIQ published 14 months ago and an ISO 27001 certificate verified as current. A cloud security practitioner is evaluating the provider for a workload involving regulated financial data. Which statement correctly characterises the assurance value of the STAR Level 1 CAIQ?

- A) A. The CAIQ provides independently verified assurance of control effectiveness because it is aligned with the Cloud Controls Matrix.
- B) B. The CAIQ provides a self-attested baseline that must be supplemented with independently verified evidence for high-risk controls.
- C) C. The CAIQ is invalid because it is more than 12 months old and must be rejected.
- D) D. The CAIQ is sufficient because it is combined with an ISO 27001 certificate.

Answer: B. The CAIQ provides a self-attested baseline that must be supplemented with independently verified evidence for high-risk controls.

Q4. A retail company deploying an e-commerce platform on a PCI DSS Level 1 certified IaaS provider assumes that the CSP's Attestation of Compliance covers all systems running in the cloud environment. Which risk does this assumption create?

- A) A. No risk, because PCI DSS Level 1 certification covers the entire cardholder data environment including customer workloads.
- B) B. The organisation may fail to implement customer-owned PCI DSS requirements, creating compliance gaps that become audit findings.
- C) C. The organisation must obtain its own PCI DSS Level 1 certification, making the CSP's AoC redundant.
- D) D. The risk is mitigated by the CSP's SOC 2 Type II report, which covers the same requirements.

Answer: B. The organisation may fail to implement customer-owned PCI DSS requirements, creating compliance gaps that become audit findings.

Q5. During contract termination, an organisation discovers that the CSP's contract only states 'data will be deleted within a reasonable time.' The organisation needs to demonstrate GDPR compliance with data erasure. Which risk does this contractual language create?

- A) A. No risk, because the CSP's ISO 27001 certification requires documented data deletion procedures.
- B) B. The organisation cannot demonstrate that all personal data — including backups and replicas — has been destroyed, creating a GDPR compliance gap.
- C) C. The organisation can resolve this by requesting a written confirmation from the CSP after termination.
- D) D. The risk applies only to primary data, as backup copies are not subject to GDPR.

Answer: B. The organisation cannot demonstrate that all personal data — including backups and replicas — has been destroyed, creating a GDPR compliance gap.

Reflection Questions

1. Which of the five certification frameworks discussed — ISO 27001, CSA STAR, PCI DSS, SOC 2, FedRAMP — are most directly relevant to the workloads your organisation currently runs or plans to run in the cloud?
2. If your organisation has existing CSP contracts, do they include explicit provisions for audit rights, data residency, incident notification timelines, and data deletion with written confirmation?
3. How would you structure a conversation with a procurement team to explain why a CSP's marketing claims about 'enterprise-grade security' are insufficient without verifiable third-party certification evidence?
4. What is the process in your organisation for annually reviewing CSP certification currency? Who owns that process, and how is it documented?
5. If a CSP declines to grant direct audit rights, what alternative evidence sources would you require, and what criteria would you use to judge whether they collectively provide sufficient assurance?

Key Takeaways

- ISO 27001 certifies a formal ISMS; ISO 27017 adds cloud-specific controls; ISO 27018 adds cloud privacy controls for PII — they are complementary, not redundant.
- Always verify ISO 27001 certification currency and issuing body accreditation through the certification body's public registry, not only the certificate document.

- CSA STAR Level 1 is self-attested; Level 2 requires independent third-party assessment. Use the CCM as a cross-framework compliance mapping tool.
- A CSP's PCI DSS AoC covers only the CSP's infrastructure scope. The Responsibility Matrix defines customer obligations — review it before placing cardholder data workloads.
- Incident notification clauses must be shorter than your regulatory notification obligations. GDPR requires 72 hours; negotiate CSP notification to 24 hours.
- Data residency, incident notification, audit rights, and data deletion with written confirmation must be explicitly negotiated and documented in the contract.
- A structured CSP evaluation framework — registry, audit reports, certification verification, contract review — creates an auditable due diligence record for regulatory and audit purposes.
- Annual re-verification of CSP certification status is a vendor risk management best practice, not a one-time onboarding activity.

Recommended Next Actions

Put this lecture to work within the next seven days:

6. Access the CSA STAR registry at cloudsecurityalliance.org/star/registry and search for one CSP your organisation uses or evaluates. Review the CAIQ if available and identify two CCM control domains most relevant to your current compliance obligations.
7. Review an existing or sample CSP contract and identify whether it contains specific provisions for audit rights, data residency, incident notification timelines, and data deletion procedures. Document any gaps.
8. Verify the ISO 27001 certification of one CSP you currently use by searching the issuing certification body's public registry and confirming the certificate number, expiry date, and accreditation status.
9. Create a one-page CSP evaluation checklist based on this lecture's framework for use in your organisation's next vendor assessment or procurement process.